

Term	Definition	Source
Router	On a network, a device that determines the best path for forwarding a data packet toward its destination. The router is connected to at least two networks and is located at the gateway where one network meets another.	NIST Glossary
	A device that determines the best path for forwarding a data packet toward its destination on a network or between networks. The router is connected to at least two network segments and is located at the gateway where one network segment meets another.	FFIEC Adapted for Supervisory Purposes
Routing	In computer networking, the process of selecting a path for traffic within a network or between multiple networks.	FFIEC Developed for Supervisory Purposes
S		
Sanitization	Actions taken to render data written on media unrecoverable by both ordinary and, for some forms of sanitization, extraordinary means.	NIST Glossary
Scalability	Refers to how well a hardware and software system can adapt to increased demands. For example, a scalable network system would be one that can start with just a few nodes but can easily expand to thousands of nodes. Scalability can be a very important feature because it means the entity can invest in a system with confidence they will not quickly outgrow it.	FFIEC Developed for Supervisory Purposes
Scheduling	A method used in the information processing facility to determine and establish the sequence of computer job processing.	ISACA Glossary
Security	The state in which the integrity, confidentiality, and accessibility of information, service or network entity is assured.	NIST Glossary
Security operations center (SOC)	The centralized unit or department responsible for monitoring and improving the entity's network for security issues and preventing, detecting, and responding to potential incidents or cyber attacks.	FFIEC Developed for Supervisory Purposes
Server	A computer or device on a network that manages network resources. Examples include file servers (to store files), print servers (to manage one or more printers), network servers (to manage network traffic), and database servers (to process database queries).	NIST Glossary
Service improvement	The actions taken to identify and execute methods to improve an entity's services and align them with its business objectives.	FFIEC Developed for Supervisory Purposes
Service level agreement (SLA)	Defines the specific responsibilities of the service provider and sets the customer expectations.	NIST Glossary
	A formal agreement between two parties that records a common understanding about products or services to be delivered, priorities, responsibilities, guarantees, and warranties between the parties. In addition, the agreement describes the nature, quality, security, availability, scope, and timeliness of delivery and response of the parties, the point(s) of contact for end-user problems, and the metrics by which the effectiveness of the process is monitored and approved, and may include other measurable objectives. The agreement should cover not only expected day-to-day situations, but also unexpected or adverse events, as the need for the service may vary.	FFIEC Adapted Definition for Supervisory Purposes

Term	Definition	Source
Service management	The process of overseeing and managing an entity's activities and resources to allow management of IT functions to support and service the entity's strategic goals and objectives. Activities involved in this process include planning, designing, transitioning, delivering, and improving services.	FFIEC Developed for Supervisory Purposes
Shadow IT	Refers to unauthorized hardware and other devices, software, or services operating in an entity's IT environment.	FFIEC Developed for Supervisory Purposes
Signature	A recognizable, distinguishing pattern associated with an attack, such as a binary string in a virus or a particular set of keystrokes used to gain unauthorized access to a system.	NIST Glossary
Signature-based detection	The process of comparing signatures against observed events to identify possible incidents.	NIST SP 800-94 Rev. 1
Single point of failure	An element in the design, configuration or implementation of a system that can cause the entire system to fail if it stops working.	FFIEC Developed for Supervisory Purposes
Social engineering	The act of deceiving an individual into revealing sensitive information, obtaining unauthorized access, or committing fraud by associating with the individual to gain confidence and trust.	NIST Glossary
Software	Computer programs (which are stored in and executed by computer hardware) and associated data (which also is stored in the hardware) that may be dynamically written or modified during execution.	NIST Glossary
Software as a service (SaaS)	The capability provided to the consumer is to use the provider's applications running on a cloud infrastructure. The applications are accessible from various client devices through either a thin client interface, such as a web browser (e.g., web-based email), or a program interface. The consumer does not manage or control the underlying cloud infrastructure including network, servers, operating systems, storage, or even individual application capabilities, with the possible exception of limited user-specific application configuration settings.	NIST Glossary
Standard image	The approved set of server configurations, applications, and systems, which can be used to deploy servers consistently and rebuild them more easily and quickly, when necessary.	FFIEC Developed for Supervisory Purposes
Standards	Rules, conditions, or requirements describing the following information for products, systems, services or practices: (i) Classification of components. (ii) Specification of materials, performance, or operations; or (iii) Delineation of procedures.	NIST Glossary
Stateful protocol analysis	The process of comparing predetermined profiles of generally accepted definitions of benign protocol activity for each protocol state against observed events to identify deviations.	NIST SP 800-94 Rev. 1
Storage area network (SAN)	A variation of a local area network (LAN) that is dedicated for the express purpose of connecting storage devices to servers and other computing devices. SANs centralize the process for the storage and administration of data. These devices could be physical or virtual.	ISACA Glossary
Structured data	Data that has a predefined data model or is organized in a predefined way.	NIST SP 1500-1 Rev. 2

Term	Definition	Source
Supply chain	A system of organizations, people, activities, information, and resources, possibly international in scope, that provides products or services to consumers.	NIST Glossary
Supply chain risk management	The implementation of processes, tools, or techniques to minimize the adverse impact of attacks that allow the adversary to utilize implants or other vulnerabilities inserted prior to installation in order to infiltrate data, or manipulate information technology hardware, software, operating systems, peripherals (information technology products) or services at any point during the life cycle.	NIST Glossary
	The implementation of processes, tools, or techniques to minimize the adverse impact of attacks that allow the adversary to exploit vulnerabilities inserted prior to installation. This is done in order to infiltrate data, or manipulate information technology hardware, software, operating systems, peripherals (information technology products) or services at any point during the supply chain (e.g., initial production, packaging, handling, storage, transport, mission operation, and disposal).	FFIEC Adapted for Supervisory Purposes
Switch	A network device that filters and forwards packets between LAN segments.	NIST Glossary
System	A combination of interacting elements organized to achieve one or more stated purposes.	NIST Glossary
System and organization controls (SOC)	The suite of services practitioners may provide relating to system-level controls of a service organization and system- or entity-level controls of other organizations. Formerly, SOC referred to service organization controls. By redefining that acronym, the AICPA enables the introduction of new internal control examinations that may be performed (a) for other types of organizations, in addition to service organizations, and (b) on either system-level or entity-level controls of such organizations.	AICPA
System development life cycle (SDLC)	The scope of activities associated with a system, encompassing the system's initiation, development and acquisition, implementation, operation and maintenance, and ultimately its disposal that instigates another system initiation.	NIST Glossary
T		
Tele-communications	The transmission, between or among points specified by the user, of information of the user's choosing, without change in the form or content of the information as sent and received.	NIST Glossary
Tenant	One who has the occupation or temporary possession of lands or tenements of another.	Merriam-Webster
	In the context of a computing environment, a customer that utilizes assets (e.g., shared applications or computing resources) or occupies space of another (e.g., cloud service provider).	FFIEC Adapted for Supervisory Purposes
Test	An evaluation tool that uses quantifiable metrics to validate the operability of a system or system component in an operational environment specified in an IT plan.	NIST Glossary

Term	Definition	Source
Third-party service provider	Any independent party to whom an entity outsources activities that the entity itself is authorized to perform, including a technology service provider.	FFIEC Developed for Supervisory Purposes
Timestamp	A token or packet of information that is used to provide assurance of timeliness; the timestamp contains timestamped data, including a time, and a signature generated by a Trusted Timestamp Authority.	NIST Glossary
Transmission	An act, process, or instance of transmitting.	Merriam-Webster
	The act of sending or conveying data, voice, audio, or video from one person or place to another.	FFIEC Adapted for Supervisory Purposes
Transmission control protocol/internet protocol (TCP/IP)	A set of communications protocols used for the exchange of information over networks and especially over the Internet.	Merriam-Webster
Trojan horse (trojan)	A useful or seemingly useful program that contains hidden code of a malicious nature that executes when the program is invoked.	NIST Glossary
Trusted timestamp authority	An entity that is trusted to provide accurate time information.	NIST Glossary
Tunneling	Technology enabling one network to send its data via another network's connections. Tunneling works by encapsulating a network protocol within packets carried by the second network.	NIST Glossary
U		
Uninterruptible power supply (UPS)	A device with an internal battery that allows connected devices to run for at least a short time when the primary power source is lost.	NIST Glossary
Unstructured data	Data that does not have a predefined data model or is not organized in a predefined way.	NIST SP 1500-1 Rev. 2
Uptime	Time during which a piece of equipment (such as a computer) is functioning or able to function.	Merriam-Webster
Useful life	The normal expected operating life of an asset.	Internal Revenue Service
Utility software (utilities)	Type of system software that allow users to perform maintenance types of tasks, usually relating to managing a computer's devices or programs. Most OSs include several utility programs, including file compression, defragmentation, diagnostics, and performance optimization.	FFIEC Developed for Supervisory Purposes
V		
Virtualization	The simulation of the software and/or hardware upon which other software runs.	NIST Glossary
Virtual machine (VM)	Software that allows a single host to run one or more guest operating systems.	NIST Glossary

Term	Definition	Source
	A simulated environment created by virtualization using software that allows a single host to run one or more guest operating systems.	FFIEC Adapted for Supervisory Purposes
Voice over internet protocol (VoIP)	A technology that allows you to make voice calls using a broadband Internet connection instead of a regular (or analog) phone line.	Federal Communications Commission (FCC)
Voice response unit (VRU)	An automated telephone answering system consisting of hardware and software that allows a caller to interact with a phone keypad or through voice recognition. Sometimes referred to as an interactive voice response (IVR) unit.	FFIEC Developed Definition for Supervisory Purposes
Vulnerability	Weakness in system security procedures, design, implementation, internal controls, etc., that could be accidentally triggered or intentionally exploited and result in a violation of the system's security policy.	NIST Glossary
Vulnerability assessment	Systematic examination of an information system or product to determine the adequacy of security and privacy measures, identify security and privacy deficiencies, provide data from which to predict the effectiveness of proposed security and privacy measures, and confirm the adequacy of such measures after implementation.	NIST Glossary
Vulnerability management	Vulnerability management (continuous) is a process to (continuously) acquire, assess, and take action on new information in order to identify vulnerabilities, remediate, and minimize the window of opportunity for attackers.	Center for Internet Security Glossary
W		
Web portal	Provides a single point of entry into the [service-oriented architecture] for requester entities, enabling them to access Web services transparently from any device at virtually any location.	NIST Glossary
Whitelist	A list of discrete entities, such as hosts, email addresses, network port numbers, runtime processes, or applications that are authorized to be present or active on a system according to a well-defined baseline.	NIST Glossary
Workstation	A computer used for tasks such as programming, engineering, and design.	NIST Glossary
Worm	A computer program that can run independently, can propagate a complete working version of itself onto other hosts on a network, and may consume computer resources destructively.	NIST Glossary
Z		
Zero trust architecture	An enterprise cybersecurity strategy that is based on zero trust principles and designed to prevent data breaches and limit internal lateral movement.	NIST SP 800-207

APPENDIX C: ABBREVIATIONS

ACF2	Access Control Facility
AI	artificial intelligence
AICPA	American Institute of Certified Public Accountants
AIO	architecture, infrastructure, and operations
API	application programming interface
BYOD	bring your own device
CDO	chief data officer
CFPB	Consumer Financial Protection Bureau
CIO	chief information officer
CIS	Center for Internet Security
COTS	commercial off-the-shelf
CPU	central processing unit
CRM	customer relationship management
CTO	chief technology officer
DBA	database administrator
DHCP	dynamic host configuration protocol
DNS	domain name system or domain name service
DDOS	distributed denial of service
DOS	denial of service
EA	enterprise architecture
EOL	end-of-life
ERM	enterprise risk management
ERP	enterprise resource planning
FDIC	Federal Deposit Insurance Corporation
FFIEC	Federal Financial Institutions Examination Council
FRB	Board of Governors of the Federal Reserve System
HVAC	heating, ventilation, and air conditioning
IaaS	infrastructure as a service
IAM	identity and access management
IDS/IPS	intrusion detection and prevention system
IoT	internet of things
IP	internet protocol
ISO	International Organization for Standardization
IT	information technology
ITAM	information technology asset management
KPI	key performance indicator
KRI	key risk indicator
LAN	local area network
MAC	media access control
MAN	metropolitan area network
ML	machine learning
NCUA	National Credit Union Administration
NIST	National Institute of Standards and Technology
NOC	network operations center

OCC	Office of the Comptroller of the Currency
OS	operating system
PaaS	platform as a service
PCI DSS	Payment Card Industry Data Security Standard
PIN	personal identification number
PSTN	public switched telephone network
RACF	Resource Access Control Facility
SaaS	software as a service
SAN	storage area network
SCM	supply chain management
SIEM	security information and event management
SLA	service-level agreement
SLC	State Liaison Committee
SOC	security operations center
SOC	system and organization controls
SOX	Sarbanes–Oxley Act
SPM	service portfolio management
TCP/IP	transmission control protocol/internet protocol
TOGAF	The Open Group Architecture Framework
UPS	uninterruptible power supply
VM	virtual machine
VoIP	voice over internet protocol
VPN	virtual private network
WAN	wide area network
ZTA	zero trust architecture

APPENDIX D: REFERENCES

Laws

- 12 U.S.C. 1861–1867, “Bank Service Company Act”
- 12 U.S.C. 1882, “Bank Protection Act”
- 12 U.S.C. 5481(14) and (26), 5514, 5515, and 5531, “Consumer Financial Protection Act of 2010”
- 15 U.S.C. 1681w, “Fair and Accurate Credit Transactions Act”
- 15 U.S.C. 6801 and 6805(b), “Gramm–Leach–Bliley Act”
- 18 U.S.C. 1030, “Fraud and Related Activity in Connection With Computers”

Consumer Financial Protection Bureau

Regulations

- 12 CFR 1005, “[Electronic Fund Transfers \(Regulation E\)](#)”
- 12 CFR 1016, “[Privacy of Consumer Financial Information \(Regulation P\)](#)”
- 12 CFR 1022, “[Fair Credit Reporting Act \(Regulation V\)](#)”

Guidance

- CFPB Compliance Bulletin and Policy Guidance; “[2016-02: Service Providers](#)” (October 2016)

Federal Deposit Insurance Corporation

Regulations

- 12 CFR 304.3(d), “[Notification of Performance of Bank Services, Form FDIC 6120/06](#)”
- 12 CFR 326, subpart A, “[Minimum Security Procedures](#)”
- 12 CFR 332, “[Privacy of Consumer Financial Information](#)”
- 12 CFR 364, appendix A, “[Interagency Guidelines Establishing Standards for Safety and Soundness](#)”
- 12 CFR 364, appendix B, “[Interagency Guidelines Establishing Information Security Standards](#)”
- 12 CFR 364, supplement A to appendix B, “[Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice](#)”

Guidance

- FIL-103-2020, “[Sound Practices to Strengthen Operational Resilience](#)” (November 2, 2020)
- FIL-52-2020, “[FFIEC Joint Statement on Risk Management for Cloud Computing Services](#)” (April 30, 2020)
- FIL-25-2020, “[Identification of Essential Critical Infrastructure Workers During the COVID-19 Response Efforts](#)” (March 26, 2020)

- FIL-14-2020, [“Interagency Statement on Pandemic Planning”](#) (March 6, 2020)
- FIL-19-2019, [“Technology Service Provider Contracts”](#) (April 2, 2019)
- FIL-63-2018, [“Cybersecurity Preparedness Resource”](#) (October 19, 2018)
- FIL-16-2018, [“FFIEC Issues Joint Statement: Cyber Insurance and Its Potential Role in Risk Management Programs”](#) (April 10, 2018)
- FIL-68-2016, [“FFIEC Cybersecurity Assessment Tool: Frequently Asked Questions”](#) (October 18, 2016)
- FIL-43-2016, [“Information Technology Risk Examination \(InTREx\) Program”](#) (June 30, 2016)
- FIL-37-2016, [“FFIEC Joint Statement on Cybersecurity of Interbank Messaging and Wholesale Payment Networks”](#) (June 7, 2016)
- FIL-55-2015, [“Cybersecurity Awareness Resources”](#) (November 23, 2015)
- FIL-28-2015, [“Cybersecurity Assessment Tool”](#) (July 2, 2015)
- FIL-13-2015, [“FFIEC Joint Statements on Destructive Malware and Compromised Credentials”](#) (March 30, 2015)
- FIL-49-2014, [“Technology Alert: GNU Bourne-Again Shell \(Bash\) Vulnerability”](#) (September 29, 2014)
- FIL-16-2014, [“Technology Alert: OpenSSL “Heartbleed” Vulnerability”](#) (April 11, 2014)
- FIL-13-2014, [“Technology Outsourcing: Informational Tools for Community Bankers”](#) (April 7, 2014)
- FIL-11-2014, [“Distributed Denial of Service \(DDoS\) Attacks”](#) (April 2, 2014)
- FIL-44-2008, [“Third-Party Risk: Guidance for Managing Third-Party Risk”](#) (June 6, 2008)
- FIL-77-2006, [“Authentication in an Internet Banking Environment: Frequently Asked Questions”](#) (August 21, 2006)
- FIL-103-2005, [“FFIEC Guidance: Authentication in an Internet Banking Environment”](#) (October 12, 2005)
- FIL-84-2002, [“Financial and Banking Information Infrastructure Committee’s Interim Policy on the Sponsorship of Private Sector Financial Institutions in the GETS Card Program”](#) (August 6, 2002)
- FIL-50-2001, [“Bank Technology Bulletin on Outsourcing”](#) (June 4, 2001)

Federal Reserve

Regulations

- Regulation H, 12 CFR 208, appendix D-1, [“Interagency Guidelines Establishing Standards for Safety and Soundness”](#)
- Regulation H, 12 CFR 208, appendix D-2, [“Interagency Guidelines Establishing Information Security Standards”](#)
- Regulation H, 12 CFR 208.61, [“Bank security procedures”](#)
- Regulation K, 12 CFR 211.5 and 211.24 (i), [“Protection of Customer and Consumer Information”](#)
- Regulation Y, 12 CFR 225, Appendix F, [“Interagency Guidelines Establishing Information Security Standards”](#)

Guidance

- SR Letter 20-24, “[Interagency Paper on Sound Practices to Strengthen Operational Resilience](#)” (November 2, 2020)
- SR Letter 20-6, “[Identification of Essential Critical Infrastructure Workers in the Financial Services Sector During the COVID-19 Response](#)” (March 27, 2020)
- SR Letter 20-3/CA Letter 20-2, “[Interagency Statement on Pandemic Planning](#)” (March 10, 2020)
- SR Letter 16-11, “[Supervisory Guidance for Assessing Risk Management at Supervised Institutions With Total Consolidated Assets Less than \\$50 Billion](#)” (June 8, 2016)
- SR Letter 15-9, “[FFIEC Cybersecurity Assessment Tool for Chief Executive Officers and Boards of Directors](#)” (July 2, 2015)
- SR Letter 13-19/CA Letter 13-21, “[Guidance on Managing Outsourcing Risk](#)” (December 5, 2013)
- SR Letter 13-16, “[End of Microsoft Support for Windows XP Operating System](#)” (October 7, 2013)
- SR Letter 12-17 / CA 12-14, “[Consolidated Supervision Framework for Large Financial Institutions](#)” (December 17, 2012)
- SR Letter 11-9, “[Interagency Supplement to Authentication in an Internet Banking Environment](#)” (June 29, 2011)
- SR Letter 06-13, “[Questions and Answers Related to Interagency Guidance on Authentication in an Internet Banking Environment](#)” (August 16, 2006)
- SR Letter 05-19, “[Interagency Guidance on Authentication in an Internet Banking Environment](#)” (October 13, 2005)
- SR Letter 05-23/ CA 05-10, “[Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice](#)” (December 1, 2005)
- SR Letter 04-17, “[FFIEC Guidance on the Use of Free and Open Source Software](#)” (December 6, 2004)
- SR Letter 01-15, “[Standards for Safeguarding Customer Information](#)” (May 31, 2001)
- SR Letter 00-17, “[Guidance on the Risk Management of Outsourced Technology Services](#)” (November 30, 2000)
- SR Letter 99-8, “[Uniform Rating System for Information Technology](#)” (March 31, 1999)
- SR Letter 98-9, “[Assessment of Information Technology in the Risk-Focused Frameworks for the Supervision of Community Banks and Large Complex Banking Organizations](#)” (April 20, 1998)
- SR Letter 96-14, “[Risk-focused Safety and Soundness Examinations and Inspections](#)” (May 24, 1996)

National Credit Union Administration

Regulations

- 12 CFR 748, “[Security Program, Report of Suspected Crimes, Suspicious Transactions, Catastrophic Acts and Bank Secrecy Act Compliance](#)”
- 12 CFR 748, appendix A, “[Guidelines for Safeguarding Member Information](#)”